Anexo D. Ticket e informe de incidente: vulnerabilidad crítica en ub-c21pn-01

Parcial SOC N1, caso C21 (ERP Pyme Fácil S.A.S.). Escenario 1: vulnerabilidad crítica detectada por Wazuh. Todas las horas están en UTC. Los campos marcados como PENDIENTE se completan con datos reales antes de la entrega final.

1. Identificación

Campo	Valor
ID del ticket en GLPI	PENDIENTE (se asigna al registrarlo en GLPI)
Tipo	Incidente de seguridad: alerta de vulnerabilidad crítica
Origen	Wazuh 4.14.9, módulo Vulnerability Detection
Fecha y hora de detección	PENDIENTE (campo de fecha de detección del hallazgo en Wazuh)
Fecha y hora de análisis	21/10/2026, 17:57 a 18:06 UTC
Analista N1	PENDIENTE
Estado	En análisis (clasificación provisional)

2. Activo afectado

Campo	Valor
Hostname	ub-c21pn-01
Agente Wazuh	001 (4.14.9)
IP (red del laboratorio)	192.168.56.11
Sistema operativo	Ubuntu Server 24.04.5 LTS
Rol en el caso	Representa el servidor del ERP
Kernel instalado y en ejecución	6.8.0-147-generic (paquete 6.8.0-147.147)

3. Descripción del hallazgo

Wazuh reporta 242 hallazgos de severidad Critical para el agente 001. Todos están asociados al paquete linux-image-6.8.0-147-generic, versión 6.8.0-147.147. El hallazgo analizado en detalle es el CVE-2026-72422.

Dato del CVE	Valor
Identificador	CVE-2026-72422
Publicación	2026/8/15
CVSS (fuente NVD)	9.8 Critical (CVSS 3.1: vector de red, complejidad baja, impacto alto en confidencialidad, integridad y disponibilidad)
Descripción	Use-after-free en ksmbd (servidor SMB del kernel de Linux), en conn->preauth_info, durante el manejo concurrente de SMB2 NEGOTIATE

4. Evidencias

N.º	Evidencia	Fecha y hora (UTC)	Origen
E1	Inventario de Vulnerability Detection filtrado por severidad Critical: 242 resultados, paquete linux-image-6.8.0-147-generic 6.8.0-147.147	21/10/2026	Dashboard de Wazuh
E2	Paquete instalado: linux-image-6.8.0-147-generic 6.8.0-147.147 (dpkg -l) y kernel en ejecución 6.8.0-147-generic (uname -r)	21/10/2026 17:57:15	linc21pn@ub-c21pn-01
E3	Página de seguridad de Ubuntu: linux en 24.04 LTS noble figura como Fixed in 6.8.0-147.147	21/10/2026	ubuntu.com/security/CVE-2026-72422

N.º	Evidencia	Fecha y hora (UTC)	Origen
E4	Base CTI de Wazuh, fuente Canonical: linux en Ubuntu 24.04 Noble afectado hasta 0:6.8.0-147 (excluyendo)	21/10/2026	cti.wazuh.com, CVE-2026-72422
E5	Comparación de versiones: dpkg --compare-versions 6.8.0-147.147 lt 6.8.0-147 devuelve falso (fuera del rango afectado)	21/10/2026 18:05:56	linc21pn@ub-c21pn-01
E6	ksmbd no está cargado (lsmod) y no hay servicio escuchando en los puertos 445 ni 139 (ss)	21/10/2026 17:59:59	linc21pn@ub-c21pn-01
E7	Ficha del CVE en la base CTI de Wazuh: CVSS 9.8, descripción y fecha de publicación	21/10/2026	cti.wazuh.com
E8	Detalle del hallazgo en Wazuh (fecha de detección, condición y fuente del escáner)	PENDIENTE	Dashboard de Wazuh
E9	CVE-2026-64268: linux en 24.04 LTS noble figura como Fixed in 6.8.0-147.147 (jammy y focal aparecen con otro estado, que no aplica a este activo)	21/10/2026, aprox. 18:10 UTC	ubuntu.com/security/CVE-2026-64268
E10	CVE-2026-72399: linux en 24.04 LTS noble figura como Fixed in 6.8.0-147.147 (jammy aparece como Vulnerable, que no aplica a este activo)	21/10/2026, aprox. 18:10 UTC	ubuntu.com/security/CVE-2026-72399

5. Análisis (triage)

1. **Versión instalada frente a la versión corregida.** Ubuntu declara el CVE-2026-72422 corregido en el kernel 6.8.0-147.147 para noble, y esa es la versión instalada y en ejecución en el activo (E2, E3).
2. **Rango afectado según la fuente de Canonical en Wazuh.** La base de Wazuh indica que solo están afectadas las versiones anteriores a 6.8.0-147. La versión instalada no es anterior, y la comprobación con dpkg lo confirma (E4, E5).
3. **Superficie de ataque.** La falla reside en ksmbd. El módulo no está cargado y no hay servicio SMB escuchando, por lo que la superficie descrita no está activa en este momento (E6). La comprobación refleja el estado actual y no descarta que el módulo se cargue más adelante.
4. **Conclusión del análisis.** Los datos de Ubuntu y de la fuente de Canonical indican que el activo no está afectado por este CVE. El hallazgo se clasifica provisionalmente como falso positivo.
5. **Causa del falso positivo.** No está confirmada. Las posibilidades que quedan por descartar son un error de comparación de versiones por parte del escáner, una detección originada en otra fuente de la base (por ejemplo rangos genéricos de NVD o de otros fabricantes) o una asociación incorrecta entre el paquete binario linux-image y el paquete fuente linux.

6. Clasificación

Campo	Valor
Severidad reportada por Wazuh	Critical (CVSS 9.8, NVD)
Severidad evaluada para el activo	Sin riesgo explotable identificado con la evidencia actual
Clasificación	Falso positivo (provisional)
Alcance verificado	CVE-2026-72422, CVE-2026-64268 y CVE-2026-72399 verificados de forma individual (los tres figuran como Fixed in 6.8.0-147.147 para noble). Los demás 239 hallazgos comparten paquete y versión, y se evalúan por muestreo

7. Decisión y acciones

- **Parcheo:** no se requiere. No hay un kernel más nuevo en las actualizaciones disponibles y las actualizaciones pendientes del sistema no corresponden a correcciones de seguridad del kernel.
- **Cierre:** el ticket se cierra como falso positivo justificado una vez completadas las verificaciones pendientes de la sección 8.
- **Seguimiento:** revisar el inventario de Vulnerability Detection cuando la base de datos de Wazuh termine de sincronizarse y comparar el conteo de críticos con el actual.
- **Escalamiento:** no aplica con la evidencia actual. Se escalaría a N2 si alguno de los CVE de la muestra figura como no corregido para la versión instalada.

8. Verificaciones pendientes

N.º	Pendiente	Estado
P1	Detalle del hallazgo en Wazuh: fecha de detección, condición y fuente del escáner	PENDIENTE
P2	Muestra de otros CVE del listado en la página de seguridad de Ubuntu: CVE-2026-64268 y CVE-2026-72399 verificados (E9, E10). Falta un CVE de otra página del inventario	Parcial: 2 de 3 CVE verificados
P3	Confirmar el efecto del estado Under evaluation en el conteo de 242 hallazgos	PENDIENTE
P4	Causa raíz del falso positivo	PENDIENTE
P5	Opcional: modinfo ksmbd para confirmar si el módulo existe en este kernel	PENDIENTE

9. Lecciones aprendidas

- Una alerta crítica de un escáner de vulnerabilidades requiere contrastar la versión instalada con la fuente del fabricante antes de decidir un parcheo.
- Un CVSS alto describe la gravedad en abstracto. El riesgo real depende de si el componente afectado está presente y expuesto en el activo.
- Los conteos masivos de hallazgos conviene revisarlos por paquete y por grupo, y documentar qué parte se verificó de forma individual y cuál por muestreo.